PROPOSAL FOR DISCUSSION · NOTHING APPROVED

Implementation Guide: Histology Redesigned

How a dermatopathology laboratory could evaluate, and only if justified adopt, a coordination companion to EMA: one reversible step at a time

Prepared for	Director of Operations, Platinum Dermatology
Prepared by	Jorge Rodriguez, histology assistant
Date	[meeting date]
Status	Proposal for discussion. Nothing in this guide has been approved.
The software	Histology Redesigned is the project; the software is called Histology Lab OS. They are the same thing.
Companion documents	*Executive brief*, *Timeline*, *Director FAQ* (this package); *Pilot proposal*; *Discovery checklist*; *Production readiness*

Read this first.

- **No one has endorsed, approved, funded, bought or partnered on this work**: not the laboratory, not ModMed, not any vendor. This guide is not a purchase request and does not ask for system access.
- The software is a **synthetic demonstration**. It uses a fictional laboratory ("Lumen Bay Dermatopathology Laboratory (fictional)") with fictional offices, staff, doctors and patients. It has never been connected to EMA, the lab network or patient information.
- **No regulatory compliance is claimed** (HIPAA, CLIA, CAP, FDA or any other). Technical controls are not compliance. Passing tests are not clinical validation. Validation is the laboratory's responsibility, under its own quality system, with the Medical Director's approval.
- **Every time and effort figure is a rough estimate**, with its assumptions stated, to be refined in Phase 0. No savings, return on investment, prices, accuracy rates or AI confidence numbers are given anywhere.
- Anything specific to the lab that I do not know is shown as **[to confirm: …]**. I make no claims about the practice's systems, volumes, staffing, finances or plans.

Titles in italics are project documents, available on request. Highlighted [to confirm: …] *items are open questions, not facts.*

Contents

1. Purpose, and how to read this guide 4
1.1 Why this guide exists 4
1.2 The position this guide takes 4
1.3 How to read it 4
1.4 Conventions 4

2. Where things stand today 6
2.1 Headline results 6
2.2 Five states 6
2.3 Known open items (recorded, not hidden) 8

3. Guiding principles 9

4. Integration options 10
4.1 Why integration decides almost everything 10
4.2 Path A: no integration (the synthetic sandbox) 10
4.3 Path B: the EMA HL7 order feed, through ModMed's lab connection and an interface engine 10
4.4 Path C: through the lab's existing LIS 11
4.5 What every real path needs from the software (development, not configuration) 11
4.6 The three paths side by side 12

5. The phased plan (Phases 0–5) 13
5.1 Phase 0: Discovery and governance (weeks 1–4) 13
5.2 Phase 1: Synthetic sandbox at the lab (weeks 5–10) 14
5.3 Phase 2: Technical foundation and integration feasibility (weeks 8–22; vendor-dependent, 2–6 months) 15
5.4 Phase 3: Validation and training (weeks 20–28) 16
5.5 Phase 4: Limited pilot (weeks 28–36) 17
5.6 Phase 5: Decision (weeks 36–38) 18
5.7 If Phase 0 chooses configure, buy or stop 18

6. The timeline 19
6.1 Before the presentation 19
6.2 After approval: summary 19
6.3 Week by week 20
6.4 Gantt chart 22
6.5 Critical path and dependencies 22

7. Roles and responsibilities 25
7.1 RACI 25
7.2 Time commitment per role (estimates to refine in Phase 0) 26

8. IT prerequisites (summary) 27

9. Validation approach 28
9.1 Whose responsibility it is 28
9.2 Start from a written intended use (Phase 1) 28
9.3 What the protocol covers (Phase 3) 28
9.4 Using the repository's test suites as supporting evidence 29
9.5 Change control after go-live 29

10. Training and adoption plan 30
10.1 Principles 30
10.2 Per role (estimates: 1–2 h per role) 30
10.3 Quick references 30
10.4 Superusers 30

10.5 Adoption 30

11. Downtime, rollback and paper fallback 32
11.1 Principles (from *Pilot proposal* section 12) 32
11.2 The paper fallback the software already provides 32
11.3 Scenarios 32
11.4 Stop triggers and rollback (agreed before Phase 4) 33

12. Data protection and privacy 34
12.1 Hosting and agreements 34
12.2 Minimum necessary 34
12.3 Access 34
12.4 Tamper-evident, not tamper-proof 35
12.5 Retention decisions the lab owes 35
12.6 Before any real data 35

13. Support and maintenance model 36
13.1 The single-developer risk 36
13.2 Options 36
13.3 Minimum conditions before patient data (checked at Gate 3) 36
13.4 Where the software and data live, and who may change them 37

14. Risk register 38

15. Decision checklist for the Director (one page) 40
Approve now: Phase 0 only (4 weeks; no patient data, no software installed on lab systems, no purchase) 40
Not being approved now 40
Decided later, at the gates 40

16. Glossary 41

Appendix A. IT prerequisites: secured-mode deployment steps 43
A.1 Host 43
A.2 Build 43
A.3 Identity-provider registration (*Sign-in architecture* sections 2, 3 and 6) 43
A.4 Environment variables (*Data protection* section 4; *Audit integrity* section 8; *Operations runbook*) 44
A.5 TLS and the reverse proxy (*Data protection* section 2) 45
A.6 Database initialization (once) (*Sign-in architecture* section 1, "Seeding"; *Stage 6 verification record* section 4, Phase E) 46
A.7 Start in secured mode 46
A.8 Identity links and roles (*Sign-in architecture* section 4; `scripts/admin.ts`) 46
A.9 Backups and restore drills (*Backup and restore*; *Operations runbook* section 5) 47
A.10 Audit verification and anchors (*Audit integrity*; *Operations runbook* section 3) 47
A.11 Health monitoring (*Operations runbook* section 2) 47
A.12 Log handling (*Operations runbook* section 1) 48
A.13 Shared workstations (*Privacy review* section 5) 48
A.14 Acceptance checks for the test environment (before Gate 2) (*Sign-in architecture* section 6; *Operations runbook*; *Stage 6 verification record* section 1) 48
A.15 Integration work (development, not configuration) (*Integration contract*; *Integration readiness*) 49

Appendix B. Evidence index 50

Appendix C. Sources 51

1. Purpose, and how to read this guide

1.1 Why this guide exists

From about four months at the bench as of October 2026 (plus earlier work at other laboratories), I keep seeing **the same specimen information copied by hand at several handoffs**. My observations, as written in *Director pitch* and *Pilot proposal* section 2, include:

- accessioners remembering which office goes to which dermatopathologist;
- parts A and B sometimes arriving as separate orders, which are hard to fix after accessioning;
- delayed replies to clarification messages to offices, for reasons we do not yet know;
- gross descriptions typed into EMA after waiting for the batch, some nights until about 9 p.m.;
- many slide labels that may be printed and applied by hand on a busy day, and a printed, hand color-coded daily list ("the bible").

These are my observations as an employee, not measured rates. The first step in this guide is to measure them properly.

This guide explains **how the laboratory would go from "an interesting demo" to "a decision"**. If the evidence supports it, it then describes how the lab could reach a small, reversible pilot. It covers who is involved, what each step needs, how long it might take, what can go wrong, and where the plan can stop.

1.2 The position this guide takes

Configure first, buy second, build last. The lab first checks what EMA and its existing tools can already do. Then it looks at existing products. A targeted companion (this software) is considered only for gaps that remain. The software is **evidence that the gaps can be closed safely**. It is not a request to buy or install anything. **A good outcome is the problem solved, even if this software is not what solves it.**

1.3 How to read it

If you are…	Read	Time
The Director of Operations, short on time	Section 15 (decision checklist), then sections 2 and 6	10 min
The Director of Operations, full picture	Sections 1–7, 11, 13–15	45 min
The Medical Director	Sections 3, 5, 9, 11, 12	30 min
The IT lead	Sections 4, 8, 12, 13 and Appendix A	45 min
The Compliance/Privacy officer	Sections 4, 12, 13 and Appendix A (A.4, A.12–A.13)	30 min

1.4 Conventions

- **[to confirm: …]** marks something only the lab, a vendor or a named role can answer. Nothing in brackets is a guess presented as fact.
- **"Estimate"** means a rough range to refine in Phase 0. The assumptions are stated next to it.
- **"Verified"** means checked by automated tests and the developer's own review, on synthetic data, on one computer. It never means clinically validated or independently assessed.
- **Three sets of names that are easy to confuse:**

Name	Where defined	What it describes
Options 1–3 (configure EMA, buy a specialist product, build a companion)	*Pilot proposal* section 4	*What* closes each gap
Rollout Modes A–D (demo, shadow, small live pilot, writeback)	*Pilot proposal* section 10	*How far* a companion is trusted
Integration paths A–C (none, EMA HL7 feed, through the LIS)	This guide, section 4	*Where the data comes from*

2. Where things stand today

Status as of the latest full run, 2026-10-24, after the last code change, on branch `stage-6-production-foundation` including changes not yet committed. The formal record of the 2026-10-19 run is Stage 6 verification record; a dated addendum to it follows the code freeze in early November, and these numbers are updated then. Also: Production readiness.

2.1 Headline results

Check	Result (2026-10-24)
Type check	Clean
Unit, integration and contract tests	**643 of 643 passed**
Demo browser suite (all guided journeys, guards, accessibility, print, recovery), on a fresh production build	**139 of 139 passed**
Secured browser suite (sign-in flow against a local test identity provider only)	**26 of 26 passed**
Production build	Builds with no network needed (the 2026-10-19 clean build had no warnings)

What this means: the code does what its tests say, on synthetic data, on one computer. **What it does not mean:** that the software is validated for patient care, secure in a real deployment, compliant with any regulation, or connected to anything.

2.2 Five states

Verified (automated tests, synthetic data)

Capability	Plain-language meaning	Evidence
Fail-closed modes	The software has three modes. **Demo** uses synthetic data and a role switch, which is not a sign-in. **Secured** requires sign-in for every page and action. Any other setting is **locked** and shows no data at all. A forgotten setting never opens a path to data.	*Sign-in architecture*
Sign-in (OIDC), sessions, idle lock, hand-over protection	Tested end to end only against a local test identity provider. Behavior with the organization's provider (claims, MFA, logout, clock skew) is implemented, not verified. Screens lock after inactivity. An action is never recorded under the wrong person on a shared workstation. Sensitive decisions require a fresh sign-in.	*Sign-in architecture*
Server-side permissions	Every page and every action is checked on the server against the person's role. Administrators and auditors cannot see clinical data.	*Security and privacy notes*
Tamper-evident audit trail	Every action is recorded and sealed into a chain. A later edit or deletion is detected when the chain is checked. (*Tamper-evident, not tamper-proof*: see section 12.)	*Audit integrity*
Signed integration boundary	A versioned message contract (`hlos.source-message` 1.0) handles duplicates, out-of-order messages, invalid data, outages and recovery. A message never changes an issued accession or patient identity.	*Integration contract*

Capability	Plain-language meaning	Evidence
Encrypted backup and verified restore	A backup can be taken while the system runs. It is encrypted. A restore goes to a new location and is checked in 11 ways before anyone uses it.	*Backup and restore*
Health checks	A simple "healthy / degraded / unavailable" signal for monitoring, plus details for administrators.	*Operations runbook*
Patient identifiers kept out of the audit trail and logs	The audit trail records which field changed, not the patient's name, birth date or MRN. Logs scrub secrets and identifiers.	*Privacy review*
Accessibility, automated	Automated WCAG 2.2 AA checks show 0 violations on the listed screens; keyboard and focus behavior is tested.	*Production readiness*, *Touch targets*

Implemented but not verified (the code exists; nothing has tested it in a real setting) (*Production readiness*)

- **Behavior with a real identity provider** (for example Entra ID or Okta): claims, MFA (`amr`/`acr`), logout and clock skew. Tested only against a local test provider.
- **HSTS and `Secure` cookies behind a real TLS proxy.** Checked from configuration in unit tests; no TLS deployment exists.
- **Rate limiting of sign-in attempts per client.** Left to the reverse proxy (Appendix A.5).
- **Audit-chain verification on a very large trail.** Every check is a full pass; its cost at scale is not measured.
- **Concurrency beyond a single SQLite file on one host.**

Simulated (labeled as simulated on screen)

- EMA, and a second simulated EHR used by one fictional office: orders, accession numbers and acknowledgements come from simulators.
- Label and cassette printers, scanners (typed as a keyboard would), office notifications, courier contents, the drafting assistant and the demo clock.
- **All patient, order and case data.**

Blocked (needs a decision, credentials or an environment the project cannot supply itself)

1. A real identity provider tenant and app registration. Production activation stays off until then.
2. A hosting environment: TLS, a secret store, encrypted storage, off-host backups, monitoring.
3. A real EMA or LIS interface (contract, test environment, interface engine); real printers, scanners and instruments.
4. An independent penetration test and threat-model review.

Requires human validation (cannot be proven by automated tests)

- Screen-reader sessions (NVDA, VoiceOver): the checklist exists and has **not been run**.
- Paper printing of the worklist on the lab's printers: only print-to-PDF has been checked.
- Real scanners and label printers, with real label stock after processing.
- Touchscreen use on the lab's actual hardware, if any [to confirm: whether benches have touchscreens].
- Workflow validation by the laboratory on its own specimens, labels and staff, under its quality system.
- Role assignments, retention periods and recovery targets, decided by the lab.

2.3 Known open items (recorded, not hidden)

From *Stage 6 verification record* section 5, updated:

- **Fixed since 2026-10-19 and re-verified on 2026-10-24** (changes not yet committed; to be re-verified on the frozen code): signed-in refusals are audited (rate-limited); the session id is rotated on re-authentication; layout issues N2–N4 at 200% zoom or very large text; a locked build now names its failing settings (never their values) in the server log line `runtime.locked_misconfigured`.
- **Still open from the security review:** the audit subject reference is unsalted.
- **Health:** a full disk can still pass the small write probe. In secured mode, monitoring tools can read only the public health signal; there is no service-account path to the details.
- **Not run at all:** screen readers, paper printing, real hardware, browsers other than Chromium, a real identity provider, a real LIS.

Further gaps that matter for real use, found while preparing this guide (they are not defects in the demo):

- **No live data source in secured mode.** The signed inbound endpoint and the simulated source pump exist only in demo mode. A real connector is **development work** (section 4.5).
- **No tool to add real staff or reference data.** The administration tool links sign-in identities, changes roles and deactivates staff. It cannot yet create staff records, offices, doctors or routing rules from scratch. In a test environment the synthetic seed supplies fictional ones (Appendix A.6).
- **MFA is enforced only by the identity provider's policy.** The application does not yet check MFA claims (`amr`/`acr`).
- **A locked build names the failing settings in the server log only.** The `/locked` page deliberately shows nothing about the configuration. The server writes one warn line, `runtime.locked_misconfigured`, naming the missing or invalid settings (never their values) on the first request after start (2026-10-24, not yet committed).

3. Guiding principles

#	Principle	What it means in practice
1	**Configure first, buy second, build last**	For each gap, ask in order: can EMA, as licensed, already do it? Does an existing product do it? Only then: would a targeted companion help? Phase 0 ends with this decision, gap by gap. Stopping, or configuring existing tools, is a **successful** outcome.
2	**EMA stays the record**	The companion coordinates handoffs. EMA keeps accessions, orders, gross reports and diagnoses. The companion is never the only place a required fact is kept.
3	**People decide identity and clinical matters**	The software suggests and blocks. It never merges orders, changes a patient link, renumbers an accession, releases a hold or decides PAS eligibility by itself. Every consequential decision is a recorded human action, with a reason. No AI makes any decision.
4	**Synthetic data until validated**	Phases 0–2 use synthetic or test data only. Validation in Phase 3 uses test data in the test environment. Any check that needs production data (for example a production interface check) is a Gate 3 decision approved by Compliance and the Medical Director [to confirm]. Patient data is otherwise used only from Gate 3 (the end of Phase 3), in Phase 4, for one workflow, after hosting, security review, validation and the Medical Director's approval.
5	**Small, reversible steps**	One phase at a time, each with a gate where the plan can stop. One workflow on one bench. A written rollback plan exists before any live use.
6	**Measure honestly**	The same definitions before and after. Medians and the slow cases. Unfinished work and missing data reported, never hidden. The extra checking a tool adds is counted against it. No staff rankings (*Pilot proposal* sections 6–7).
7	**No single point of failure in people**	The software must not depend on one employee. A developer other than Jorge is named at Gate 1, before any interface work, and a support owner with a second maintainer is in place before any patient data is used (section 13).

4. Integration options

4.1 Why integration decides almost everything

Without a data feed, a companion would need staff to type information that already exists in EMA. That is **double entry**, the very burden this project is trying to remove. A live pilot with real benefit therefore needs some approved way to receive orders, and possibly accession and specimen information. Integration is also the **slowest and least predictable** part of the plan, because it depends on vendors, contracts and fees.

One question comes before any path: does the lab receive its orders as an *outside* laboratory (over an interface), or does it work inside EMA's in-house Pathology module? A ModMed page notes that in-house labs can use the Pathology module, so the order might never travel over HL7 at all (see *Research notes*, R3 and S13). A companion would then need ModMed API access to that data, or could not get it at all, and Path B below (the basis of Phases 2–4 and of the plan's totals) might not exist. In that case the build path would likely stop at Gate 0. **[to confirm: how orders reach the lab today, from EMA offices and from any office on another EHR]**

4.2 Path A: no integration (the synthetic sandbox)

What it is	The application in demo mode, with synthetic data only, on a lab-controlled computer that is not connected to EMA or the lab network for data.
What it needs	A computer approved by IT [to confirm: a standalone laptop or a workstation outside the clinical network]; Node.js 22 or later; a one-time package download, or a copy built elsewhere (the build itself needs no network); the lab's scanners and a printer for bench tests.
What it is good for	Phases 0–1: usability sessions with real staff, real scanners, monitors and printers; testing whether the workflow ideas fit the lab; drafting an intended use. **Decision-grade evidence without any patient data.**
What it cannot do	Any live use. It cannot measure real time savings, because no real work flows through it.
Unknown	[to confirm: IT's rules for installing software on a lab-controlled computer, even an offline one].

4.3 Path B: the EMA HL7 order feed, through ModMed's lab connection and an interface engine

What it is	EMA sends lab orders out as HL7 order messages; an **interface engine** (software that translates and routes messages between systems) maps them to the companion's contract `hlos.source-message` 1.0 (*Integration contract*).
What public sources say	ModMed's pages describe EMA sending clinical and pathology lab orders out as **HL7 ORM** messages and receiving pathology results as **HL7 ORU** messages; results can carry a PDF and be matched to the patient chart [G1, G2]. Labs connect through ModMed's lab connection (partner) process [G3]. ModMed's API portal also documents a **Certified FHIR R4 API** (OAuth 2.0 / SMART on FHIR, mainly read and search) and a **proprietary EMA API** [G4]. **These are vendor descriptions. Each must be confirmed with ModMed.** Which API, if any, fits order intake is a question for ModMed.
What it needs	ModMed's agreement to connect, through its lab connection process [G3]; an interface specification; a test environment with test patients; a contract and any fees; an interface engine (an existing one, if the organization has one [to confirm], or a new one); network transport agreed with IT (typically a VPN or mutual TLS, not the demo's signing scheme); a production connector in the companion (section 4.5).

What it would give	Orders, as they are placed. An HL7 order message generally carries patient demographics, the ordering clinician and the requested procedure; what EMA's feed actually contains for this lab (office, specimen sites, parts, amendments) is [to confirm with ModMed].
What it would not give (as far as public documentation shows)	Internal histology data: accession numbers, parts, cassettes and blocks, slides, gross text, stain work orders. ModMed's public API pages do not document them. "Not documented" does not mean "does not exist" (*Research notes* section 4). Without them, those facts stay with staff attestation ("entered in EMA, attested by a named person"), which is never shown as a system acknowledgement.
Unknown	[to confirm: whether the lab is set up as an in-house Pathology-module lab or as an outside lab]; [to confirm: whether an order feed already exists and whether an approved copy could feed a test environment (*Discovery checklist* 5.5)]; HL7 version, message types, how amendments and cancellations are sent; fees; lead time; who owns the interface on each side.
Sources	[G1] https://www.modmed.com/synapsys/hl7/ · [G2] https://www.modmed.com/?p=31624 · [G3] https://www.modmed.com/lab-connect/ · [G4] https://portal.api.modmed.com

4.4 Path C: through the lab's existing LIS

What it is	If the lab uses a laboratory information system (LIS) separate from EMA [to confirm: whether one exists, or EMA's Pathology module is the LIS], the companion would receive data from that LIS rather than from EMA directly.
What public sources say	Third-party LIS vendors advertise ModMed integrations; for example, LigoLab describes one for dermatopathology [G5]. **This is a vendor claim**, not independent evidence and not confirmed for this lab. It is relevant mainly to the *buy second* option: if an LIS already does what is needed, the companion is not needed.
What it needs	The LIS vendor's interface specification, a test environment, a contract and fees; the same interface engine and connector work as Path B.
What it might give	Possibly more histology-internal data (accession, specimen, block, slide) than an EHR order feed, because that is the LIS's own domain. [to confirm with the LIS vendor]
Unknown	Everything specific: which LIS, which version, which interfaces are licensed, whether the LIS already drives the label printers and scanners (*Discovery checklist* 6.1), fees, lead time.
Source	[G5] https://www.ligolab.com/post/seamless-diagnosis-mapping-why-ligolabs-modmed-integration-matters-for-dermatopathology

4.5 What every real path needs from the software (development, not configuration)

The demo's integration boundary is a **stand-in** that proves the rules: duplicates, ordering, rejections, outages and recovery. It is not a production connector. Before Path B or C can carry test messages:

1. **A production inbound connector.** Today the inbound endpoint exists **only in demo mode**, with simulated sources. A real connector must accept real sources in secured mode, with an independent secret or certificate per source, behind the transport IT chooses.
2. **The mapping.** The interface engine maps HL7 ORM (or the LIS's messages) onto `hlos.source-message` 1.0. The contract already lists how HL7 v2 and FHIR fields correspond (*Integration contract* section 13).
3. **Accession handling.** Today an inbound accession notice is only *compared* with the local record. Adopting an accession number issued by EMA or the LIS needs a new, reviewed step.
4. **An outbound path, if needed.** None exists. Whether one is needed depends on the workflow chosen.

5. **Staff and reference data loading** (offices, doctors, routing rules) for the real lab.

Effort for these items is not yet estimated [to estimate at Gate 1, by the connector developer named there (section 13)]. It sits on the critical path (section 6.5). The planned weeks for it are 13–19.

4.6 The three paths side by side

	Path A: none	Path B: EMA HL7 feed	Path C: through the LIS
Patient data	None	Yes, after approvals	Yes, after approvals
Vendor dependency	None	ModMed, interface engine	LIS vendor, interface engine
Supports	Phases 0–1	Phases 2–4	Phases 2–4
Histology-internal data	Synthetic only	Probably not (to confirm)	Possibly (to confirm)
Fees	None	Unknown until quoted	Unknown until quoted
Typical lead time	Days	Vendor-dependent, roughly 2–6 months from the first request (estimate)	Vendor-dependent, roughly 2–6 months from the first request (estimate)
Biggest unknown	IT's install rules	Whether the lab's orders travel over HL7 at all	Whether a separate LIS exists

5. The phased plan (Phases 0–5)

Weeks are counted from approval; week 1 starts with the Phase 0 kickoff. Phases overlap on purpose. **Each phase ends at a gate where the plan can stop.** Nothing is purchased or contracted before the gate that authorizes it. **Vendor scoping** (questions, a draft specification, a quote and a request for a test environment) runs during Phases 0–1 with no contract and no data; only signing waits for Gate 1.

Phase	Weeks	One-line purpose	Gate question
0. Discovery and governance	1–4	Learn what is really happening and what existing tools can already do	Configure, buy, build or stop?
1. Synthetic sandbox at the lab	5–10	Test the ideas at real benches with real hardware, no patient data	Is it usable, and is the intended use approved?
2. Technical foundation and integration feasibility	8–22 (vendor-dependent: 2–6 months)	Build a secure test environment with real sign-in and test interface messages	Can it run securely, and can the data flow?
3. Validation and training	20–28	Prove it works for one intended use, under the lab's quality system, and train people	Is it ready for a limited pilot?
4. Limited pilot	28–36	One workflow, one bench: shadow first, then live with a rollback plan	Weekly: continue or stop?
5. Decision	36–38	Decide on pre-agreed criteria	Continue, expand, change or stop?

How this maps to the earlier proposal: Phase 0 covers stages 1–2 (observe, baseline) of *Pilot proposal* section 5; baseline measurement can continue into Phase 1 if four weeks are not enough for representative days. Phase 1 is stage 3 (synthetic demo review). Phase 4 is stage 4 (shadow comparison, Rollout Mode B), followed by a small live pilot (Mode C). Phase 5 is stage 5. **Rollout Mode D (writing back to EMA or controlling printers) is not part of this plan.**

5.1 Phase 0: Discovery and governance (weeks 1–4)

Goal. Find out which observed burdens are real and how big they are, what EMA and existing tools already do, and whether anything is left that a companion should address.

People. The sponsor (Director of Operations), Jorge, the Medical Director, the IT lead and the Compliance/Privacy officer.

Activities

1. Kickoff: confirm the sponsor, the Phase 0 group and the observation ground rules (staff consent, no patient identifiers in notes, no individual rankings).
2. Answer the questions in *Discovery checklist*, recording who answered and when. "We don't know" is a valid answer.
3. Observe and time representative workflow cycles, **with staff consent**, recording times and categories only, never names, MRNs or accession numbers.
4. Agree the metric definitions (*Pilot proposal* section 6, M1–M11 and the balancing measures), so that any later comparison uses the same method.
5. Inventory EMA modules and settings in use, the LIS if any, label printers, scanners and bench computers.
6. Ask ModMed, and any LIS vendor, what is already licensed, configurable and interfaced. Ask for demonstrations with test data. **Questions only: no contract, no data shared.** The questions go through

[to confirm: the EMA administrator or the IT lead]. Because the interface is the longest pole (section 6.5), this conversation starts in week 1. First among the questions: does the lab receive orders over an interface, or work inside EMA's Pathology module (section 4.1)?

7. Fill in the gap-by-gap table (*Pilot proposal* section 4) with configure, buy or build for each gap.
8. If the outcome is *build*: choose the one pilot workflow [to choose in Phase 0], for example courier intake reconciliation or tray assembly scan verification.
9. With HR or legal, check the employer policies on employee-built tools, on presenting this work, and on using an AI coding assistant for work-related software (*Discovery checklist* 12.5) [to confirm with HR]. Settle ownership of the code in writing, and plan its move to a repository the organization controls (section 13.3).

Deliverables. Answered discovery checklist; a corrected workflow map; agreed metric definitions; an observation summary (aggregate, no identifiers); an equipment and systems inventory; a written recommendation, gap by gap; a written note on ownership and policies.

Entry criteria. The Director approves Phase 0. The approach to staff consent for observation is agreed at the kickoff. Jorge's time for Phase 0 is agreed [to confirm with his manager].

Exit gate (week 4). The sponsor, with the Medical Director, records one decision per gap: **configure, buy, build, or stop**. Stopping, or configuring existing tools, is a **success**. **If vendor answers are missing at week 4,** Gate 0 decides the gaps that are answered and may extend Phase 0 by up to [to confirm] weeks for the rest. Nothing is built while waiting.

Go/no-go questions

- Are the observed burdens real and large enough to matter, by the agreed measures?
- Can EMA configuration, training or access changes close them?
- Does an existing product close them at acceptable cost and effort?
- If anything remains: is there a realistic data path (section 4), and is there an owner for long-term support (section 13)?
- Does the lab want to spend Phase 1 effort on the remaining gaps?

5.2 Phase 1: Synthetic sandbox at the lab (weeks 5–10)

Goal. See whether the companion's workflow ideas fit real benches, real hardware and real people, **without any patient data**.

Activities

1. Install the application **in demo mode** on a lab-controlled computer approved by IT, **not connected to EMA or the network for data** (Path A).
2. Adjust the synthetic data so it mirrors the lab's *structure* (the number of offices, doctors and benches, the shape of a day), with **fictional names only** [to confirm: which structural facts may be used].
3. Run bench usability sessions: 1–2 h each, 5–8 people across roles (estimate). Participants try the guided steps and say what is wrong.
4. **Label decode check:** can the lab's scanners read the application's label format (DataMatrix with readable text) from test prints? The label printer is simulated today; driving the lab's label printers would be later development work (*Integration readiness*).
5. **Print checks:** the paper print test of the worklist snapshot on the lab's printer, using the checklist in *Print verification* section 6; a review of label layouts against current labels.

6. **Accessibility checks:** the screen-reader checklist (*Screen-reader checklist*) [to confirm: who can run it]; the touchscreen check (*Touch targets*) if benches have touchscreens.
7. Fix usability findings and re-check them.
8. Write the **intended use**: which decisions the tool supports, for which workflow, by which roles, and what it never does (section 9.2).

Owners. Jorge (sessions, fixes); bench staff (participants); IT lead (computer approval); Medical Director (intended use); sponsor (session scheduling).

Deliverables. Usability findings with fixes; label decode results; paper print results; screen-reader and touchscreen results (or the reason they were not run); a written intended use.

Entry criteria. Gate 0 chose *build* for at least one gap. IT approves the sandbox computer and its isolation. The code has moved to a repository the organization controls, and the early prompt file that names the employer and one real role-holder has been deleted and purged from the history and from Jorge's personal GitHub copy (section 13.3).

Exit gate (week 10). Usability findings addressed; the intended use approved by the Medical Director; **go or no-go for Phase 2**. **The support model is chosen and the developer who will build the connector is named** (internal IT or contracted). Jorge is never the only developer of code that receives test or real patient messages. Planning work for Phase 2 may start in week 8, but nothing is purchased or contracted before this gate.

Go/no-go questions

- Did bench staff find the workflow helpful, or did it add steps?
- Do the lab's scanners and printers work with the label and print formats?
- Is the intended use narrow, clear and approved?
- Is the expected benefit still worth an interface, hosting, a security review and validation?
- Is a connector developer other than Jorge named, with the connector effort estimated?

Decision-grade stopping point. Phases 0–1 together (about 10 weeks) are the **cheapest decision-grade path**, with no patient data and nothing installed on clinical systems. The lab can stop here with real evidence.

5.3 Phase 2: Technical foundation and integration feasibility (weeks 8–22; vendor-dependent, 2–6 months)

Goal. Show that the software can run securely in a **test** environment, with real sign-in and test interface messages. **No production patient data yet.**

IT activities (concrete steps in Appendix A)

- Hosting: an on-premises virtual machine, or a cloud service the provider designates as HIPAA-eligible, under a business associate agreement (BAA) [to confirm with Compliance]; encrypted storage; a service account.
- TLS through a reverse proxy; an app registration at the organization's existing identity provider (for example Entra ID or Okta, whichever the organization already uses [to confirm]); a secret store.
- Scheduled encrypted backups, a restore drill, monitoring of `/api/health`, log handling.
- An **independent security review or penetration test**, 2–4 weeks inside this window (estimate), planned for weeks 19–22 so that it covers the new inbound connector as well as the platform.

Interface activities

- Through ModMed's lab connection process and/or the LIS vendor: a specification, a test environment, a contract and any fees. Scoping started in Phase 0 without a contract; the contract is signed only after Gate 1. The planned case needs the **vendor specification and test environment by about week 15**, about 3 months after approval.
- An interface engine maps HL7 ORM (or the LIS's messages) to the `hlos.source-message` 1.0 contract (*Integration contract*).
- The production connector and related development (section 4.5), **weeks 13–19** [effort to estimate at Gate 1], by the developer named at Gate 1.

Owners. IT lead (hosting, identity, security review); sponsor (contract and fee decisions); Compliance/Privacy officer (BAA, data agreement); vendor(s) (specification, test environment); the connector developer named at Gate 1 (connector).

Deliverables. A running secured test environment; an identity-provider registration; a backup and restore drill record; a security review report with findings triaged; an interface specification and test-message results; vendor quotes for fees.

Entry criteria. Gate 1 passed. The sponsor approves spending on the items quoted. Compliance confirms what agreements are needed before any vendor sees test or real data.

Exit gate (week 22 in the best case, or later if the vendor is slower). Secured mode working in a **test environment**, with real sign-in and test interface messages; security findings fixed or accepted by the right owner; no production patient data used. If the vendor test environment is not ready by about week 15, plan on the delay case (section 6.4): Gate 2 moves out, up to about week 34.

Go/no-go questions

- Does sign-in work with the organization's identity provider, including MFA by policy?
- Do test messages arrive, map correctly and reconcile (duplicates, amendments, cancellations, outages)?
- Are the security review's findings, including those on the connector, fixed or formally accepted?
- Are the interface fees and timelines acceptable?
- Is the support owner confirmed, with a second maintainer identified (section 13)?

5.4 Phase 3: Validation and training (weeks 20–28)

Goal. Prove that the configured system does what the intended use says, for the one chosen workflow, under the lab's quality system, and prepare the people who will use it.

Activities

1. A **validation plan and protocol** under the lab's quality system, approved by the Medical Director (section 9). The repository's automated test suites are **supporting evidence only**.
2. Execute the protocol, including interface checks, in the test environment with test data. Any check that needs production data (for example a production interface check) is a Gate 3 decision approved by Compliance and the Medical Director [to confirm].
3. Write the **downtime procedure** and rehearse it (section 11).
4. **Role-based training**, 1–2 h per role (estimate), plus a one-page quick reference per role; name superusers (section 10).

5. Put the **support agreement** in place, for the model chosen at Gate 1, with the support owner and a second maintainer (section 13).
6. A **go-live readiness review**.

Owners. Medical Director (approves the plan and the report); a validation lead [to confirm: role]; Jorge (test execution support, training material); IT (environment, change control); sponsor (readiness review).

Deliverables. Approved validation plan; executed protocol with results and deviations; validation report; downtime procedure; training records; quick references; support agreement; readiness review record.

Entry criteria. Gate 2 passed. The intended use is approved. The pilot workflow is fixed. Validation planning may start in week 20, while Phase 2 finishes; protocol execution starts only after Gate 2.

Exit gate (week 28): go-live readiness review. Validation report approved by the Medical Director; training done; downtime procedure rehearsed; rollback plan and stop triggers written; support owner and second maintainer in place; Compliance agrees the data handling.

Go/no-go questions

- Did validation pass for the intended use, with deviations resolved?
- Can every pilot user sign in, and do they know the fallback?
- Is the rollback plan rehearsed, with a named person who can stop the pilot?
- Is support in place for the pilot hours?

5.5 Phase 4: Limited pilot (weeks 28–36)

Goal. Learn whether the companion helps with **one workflow on one bench**, measured against the baseline, including the burden it adds.

Scope. One workflow on one bench, for example courier intake reconciliation or tray assembly scan verification [to choose in Phase 0].

Activities

1. **About 2 weeks in shadow (parallel) mode** (Rollout Mode B): the companion runs alongside the usual process; EMA and paper remain the record; staff are not asked to rely on it.
2. **Live on one bench** (Rollout Mode C), with the rollback plan ready, if the shadow review allows it.
3. **Weekly review** against the baseline, using the pre-agreed metric definitions and balancing measures: verification burden, double entry, notification volume, data agreement with EMA, staff feedback (*Pilot proposal* section 6.3).
4. Apply the stop triggers if they fire (section 11.4).

Owners. Sponsor (weekly review, stop authority); Medical Director (safety concerns); the bench supervisor [to confirm: role]; superusers; support owner; Jorge (coordination, data collection).

Deliverables. Weekly review notes; a pilot report with medians, the slow cases, open items and missing data.

Entry criteria. Gate 3 passed.

Exit. End of week 36, or earlier if a stop trigger fires.

Go/no-go questions (weekly)

- Is the data in agreement with EMA at the agreed level?
- Is the added checking and double entry within the agreed limit?

- Any near miss or safety concern linked to the pilot?
- Do staff want to continue?

5.6 Phase 5: Decision (weeks 36–38)

Goal. Decide on **pre-agreed criteria**, written in Phase 0 and refined at Gate 3: **continue, expand, change or stop**.

Activities. Compile the pilot report; compare against the baseline; count the added burden; review support, cost and risk; write the decision record. Any expansion is a **new decision**, with its own approval, validation scope and rollback plan.

Owners. Sponsor and Medical Director decide; IT and Compliance advise; Jorge prepares the report.

Deliverables. A decision record.

5.7 If Phase 0 chooses configure, buy or stop

Gate 0 outcome	What happens next
Configure EMA (or retrain, or change access)	Work with ModMed and the EMA administrator on the change. The lab's own change control and validation apply. The companion is not used. Re-measure with the same definitions. **This is a success.**
Buy an existing product	The vendor's implementation plan replaces Phases 1–3. The principles of this guide still apply: validation, training, a limited pilot with rollback, and a decision on criteria. The companion is not used, except perhaps to clarify requirements.
Build for the gaps that remain	Phases 1–5 as written.
Stop	The findings are recorded. Nothing else is needed.

6. The timeline

All durations are **estimates**. The planned case is the **best case**. It assumes that people are available at the effort levels in section 7, that **a vendor specification and test environment are available by about week 15, about 3 months after approval** (vendor scoping starts in week 1, with no contract until Gate 1), that the lab's orders do travel over an interface (section 4.1), and that no phase finds a reason to stop. **If the vendor test environment is not ready by about week 15, plan on the 12-month case.** The standalone version is in *Timeline*.

6.1 Before the presentation

Dates	What	Who
Mon 26 – Fri 30 Oct 2026	Software refinements and the presentation package (this work)	Jorge
Mon 2 – Fri 6 Nov 2026	Jorge reviews every document, fills in the [to confirm] items he already knows from his own role (**never patient data**) and rehearses the demo. The code is frozen and the checks are re-run and recorded.	Jorge
Mon 9 – Fri 13 Nov 2026	**Target meeting week.** A 30-minute meeting: a 5-minute demo, a 10-minute proposal, then questions	Director of Operations, Jorge
Mon 16 – Fri 20 Nov 2026	Fallback meeting week	Same

The ask at the meeting: approval for Phase 0 only (discovery and observation; no patient data; no new software installed on lab systems).

6.2 After approval: summary

Phase	Weeks from approval	Illustrative dates (if Phase 0 starts Mon 30 Nov 2026)
0. Discovery and governance	1–4	30 Nov – 23 Dec 2026
1. Synthetic sandbox at the lab	5–10	28 Dec 2026 – 5 Feb 2027
2. Technical foundation and interface	8–22 (vendor-dependent, 2–6 months)	18 Jan – 30 Apr 2027
3. Validation and training	20–28	12 Apr – 11 Jun 2027
4. Limited pilot	28–36	7 Jun – 6 Aug 2027
5. Decision	36–38	2 Aug – 20 Aug 2027

Totals (estimates)

- **Best case: about 7–9 months** from approval to the end of a limited pilot, if a vendor specification and test environment are available by about week 15 (about 3 months after approval).
- **Up to about 12 months** with vendor or contract delays (section 6.4).
- **The cheapest decision-grade path is Phases 0–1 only: about 10 weeks, with no patient data** (illustratively, to about 5 Feb 2027).

The illustrative dates assume approval in the target meeting week and a kickoff within about 2 weeks of approval, on Monday 30 November 2026. That leaves time to convene four busy roles and agree the consent

approach, and it avoids Thanksgiving week. **Every date moves with the actual approval and kickoff dates**, by about a week if the fallback meeting week is used. Weeks 4 and 5 (21 Dec and 28 Dec) are year-end holiday weeks, so Gate 0 may fall in the first week of January [to confirm: the lab's schedule and busy periods].

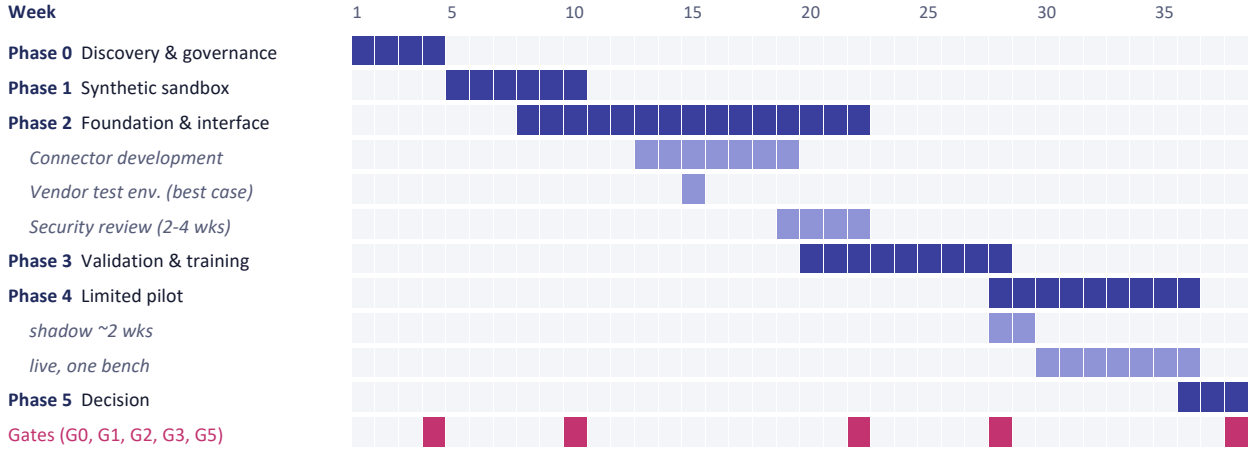
6.3 Week by week

Week	Week of (illustrative)	Phases	Main activity	Gate or milestone
1	30 Nov 2026	0	Kickoff; consent approach for observation agreed; questions sent to ModMed and any LIS vendor (vendor scoping starts, no contract)	Kickoff
2	7 Dec	0	Observation and timing begin (with consent); inventory of systems and equipment; HR or legal policy check begins	
3	14 Dec	0	Observation continues; metric definitions agreed; small-group review of the synthetic demo	
4	21 Dec	0	Discovery answers summarized; gap-by-gap recommendation written	**Gate 0: configure / buy / build / stop** (holiday week [to confirm]; may move to early January)
5	28 Dec	1	Code moved to an organization-controlled repository; early prompt file purged. Sandbox installed on a lab-controlled computer (demo mode, no data connection); synthetic data shaped like the lab, fictional names	Holiday week [to confirm]
6	4 Jan 2027	1	Bench usability sessions begin; label decode check with the lab's scanners	
7	11 Jan	1	Usability sessions continue; paper print test; touchscreen check if relevant	
8	18 Jan	1, 2	Screen-reader checklist [to confirm: tester]; intended use drafted. Phase 2 planning: hosting options, identity-provider request; vendor scoping continues (draft specification, quote, test-environment request; no contract, no purchase)	Phase 2 planning starts
9	25 Jan	1, 2	Usability fixes re-checked; Compliance begins the agreement review	
10	1 Feb	1, 2	Intended use reviewed by the Medical Director; support model chosen; connector developer named and connector effort estimated	**Gate 1: go / no-go for Phase 2** (end of the 10-week path); a vendor contract can be signed only after it
11	8 Feb	2	Test host: encrypted storage, TLS proxy, service account	
12	15 Feb	2	Identity-provider test registration; secrets in the secret store; secured mode starts with synthetic data	
13	22 Feb	2	Test identities linked and roles assigned; sign-in, lock and hand-over checks. **Connector development, weeks 13–19** [effort to estimate at Gate 1] begins from the vendor's draft specification	
14	1 Mar	2	Scheduled backups; first restore drill; health monitoring; log handling. Connector development	
15	8 Mar	2	Vendor test environment and specification [vendor-dependent]; interface-engine mapping designed. Connector development	**Vendor test environment ready (best case)**
16	15 Mar	2	First test messages through the interface engine into the connector. Connector development	
17	22 Mar	2	Test messages; reconciliation against vendor test data. Connector development	

Week	Week of (illustrative)	Phases	Main activity	Gate or milestone
18	29 Mar	2	Duplicates, amendments, cancellations and outages exercised with test messages. Connector development	
19	5 Apr	2	Connector development complete; independent security review begins (platform and connector)	
20	12 Apr	2, 3	Security review. Phase 3: validation plan drafted with the Medical Director (planning only)	
21	19 Apr	2, 3	Security review ends; findings triaged; fixes. Validation protocol written	
22	26 Apr	2, 3	Fixes re-tested; end-to-end demonstration of the secured test environment	**Gate 2: foundation and interface feasible**
23	3 May	3	Validation protocol approved; execution begins (test environment, test data)	
24	10 May	3	Validation execution; interface checks	
25	17 May	3	Validation execution; downtime procedure written	
26	24 May	3	Role-based training; quick references; superusers; support agreement in place	
27	31 May	3	Training; downtime and rollback drill; validation report	
28	7 Jun	3, 4	Go-live readiness review; shadow mode begins on one bench	**Gate 3: readiness review**
29	14 Jun	4	Shadow mode; data-agreement checks	
30	21 Jun	4	Shadow review; live on one bench with rollback plan	Shadow-to-live decision
31	28 Jun	4	Live; weekly review against baseline	Weekly review
32	5 Jul	4	Live; weekly review	Weekly review
33	12 Jul	4	Live; weekly review	Weekly review
34	19 Jul	4	Live; weekly review	Weekly review
35	26 Jul	4	Live; weekly review	Weekly review
36	2 Aug	4, 5	Pilot ends; results compiled	
37	9 Aug	5	Decision review against pre-agreed criteria	
38	16 Aug 2027	5	Decision recorded	**Gate 5: continue / expand / change / stop**

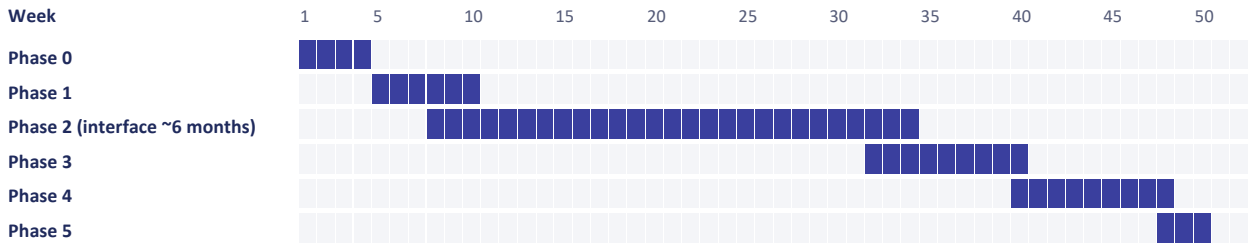
6.4 Gantt chart

Planned case, the best case (vendor specification and test environment by about week 15). Dark bars show a phase in progress, lighter bars an activity inside a phase, and pink cells the gates.



Gates: G0 week 4, G1 week 10, G2 week 22, G3 week 28, G5 week 38 (Phase 4 has weekly continue-or-stop reviews instead of a numbered gate). The security-review weeks are a placeholder, to be scheduled with the tester; they come after the connector is built so the review covers it.

Delay case (the vendor test environment arrives about 3 months late, about week 27). Gate 2 moves to about week 34 and Phases 3–5 move about 12 weeks later. The end is about week 50, up to about 12 months:



6.5 Critical path and dependencies

The vendor interface is the longest pole. The critical path runs:

Vendor scoping from week 1 → Gate 0 (*build*) → Gate 1 (support model chosen, connector developer named, contract signed) → vendor specification and test environment (by about week 15 in the best case) → connector development (weeks 13–19) and interface-engine mapping → security review including the connector (weeks 19–22) → Gate 2 → validation of the interface and workflow → training → readiness review → pilot → decision.

Dependency	Needed by	Owner	Lead time (estimate or unknown)	On the critical path?
Answers from ModMed / LIS vendor on what is licensed and configurable, and whether orders travel over an interface at all	Gate 0 (week 4); Phase 0 may be extended for unanswered gaps	Sponsor, with Jorge	Unknown [to confirm]	Yes, for the decision

Dependency	Needed by	Owner	Lead time (estimate or unknown)	On the critical path?
IT approval of the sandbox computer	Phase 1 start (week 5)	IT lead	Unknown [to confirm]	For Phase 1 only
Interface specification and test environment	By about week 15 (test messages from week 16)	Vendor; scoping without a contract from week 1	2–6 months from the first request (estimate, vendor-dependent); week 15 is the best case	**Yes, the longest pole**
Interface contract and fees	Signed only after Gate 1 (week 10)	Sponsor	Unknown until quoted	Can become critical
Support model chosen; connector developer named	Gate 1 (week 10)	Sponsor	Unknown	**Yes**: no interface work starts without it
Connector development (section 4.5)	Weeks 13–19, before the security review	The connector developer named at Gate 1	Not yet estimated [to estimate at Gate 1]	**Yes**
Hosting environment	Week 11	IT lead	Unknown [to confirm: IT's queue]	Can become critical
Identity-provider app registration	Week 12	IT lead	Usually short if the organization already runs a provider [to confirm]	Rarely
Business associate or data agreements	Before any vendor or host sees real data	Compliance/Privacy officer	Unknown [to confirm]	Can become critical
Independent security review, including the connector	Weeks 19–22, before Gate 2	IT lead	2–4 weeks of testing, plus scheduling lead time (unknown)	Can become critical
Support owner and second maintainer in place	Gate 3 (week 28)	Sponsor	Unknown	Yes, for go-live
Validation plan approval	Week 23	Medical Director	Part of the Medical Director's 4–8 h (estimate)	Yes
Staff time for sessions and training	Phases 1 and 3	Sponsor, supervisor	Scheduling around busy periods [to confirm]	Can delay Phases 1 and 3

What could shorten the plan: Gate 0 chooses *configure* (no build path at all); an existing order feed can be copied to a test environment with approval (*Discovery checklist* 5.5); IT already has standard virtual-machine templates, a reverse proxy and an identity provider.

What could lengthen it: a vendor test environment later than about week 15 (then plan on the 12-month case); vendor contract or fee approval; security findings that need redesign; a wider validation scope; staff availability; holidays; the connector development effort.

What could stop it: if the lab works inside EMA's Pathology module and orders never travel over an interface, a companion may not be able to get the data at all (section 4.1). The build path would then likely stop at Gate 0.

7. Roles and responsibilities

7.1 RACI

R = does the work · **A** = accountable, decides · **C** = consulted · **I** = informed. Roles are titles. Who fills each one is [to confirm].

Activity	Director of Operations (sponsor)	Medical Director	IT lead	Compliance/Privacy officer	Jorge	Bench staff and supervisor	Vendors (ModMed, LIS)	Support owner / connector developer (named at Gate 1)
Phase 0 approval and kickoff	A	C	C	C	R	I		
Observation and timing (with consent)	A	I		C	R	C		
Metric definitions	A	C		C	R	C		
Discovery questions to vendors	A	C	C	C	R		C	
Gate 0: configure / buy / build / stop	A	R	C	C	C	I		
Support model and connector developer (Gate 1)	A	C	R	C	C			I
Sandbox computer and isolation	I		A	C	R			
Bench usability sessions	A	I			R	R		
Intended use	C	A	C	C	R	C		
Hosting, TLS, secrets, backups, monitoring	I		A	C	C			R
Identity-provider registration and role review	I	A (role review)	A/R (registration)	C	C			C
Security review / penetration test	I		A	C	C			R (fixes)
Interface specification, contract, fees	A	I	R	C	C		R	C
Connector development and mapping	I		C		C		C	A/R
BAA and data agreements	C		C	A	I		C	C
Validation plan and report	C	A	C	C	R	C		C
Training and quick references	A	C			R	R (superusers)		C
Downtime and rollback procedure	A	C	R	C	R	C		R
Go-live readiness review	A	A	C	C	R	C		C
Pilot weekly review and stop authority	A	C	C	C	R	C		C
Phase 5 decision	A	A	C	C	R	I		C

Where two roles are marked A (readiness review, Phase 5), both must agree.

7.2 Time commitment per role (estimates to refine in Phase 0)

Role	Rough effort	Assumptions
Sponsor (Director of Operations)	About 1 h per week, plus gate decisions	A short weekly check-in; gates at weeks 4, 10, 22, 28 and 38
Medical Director	About 4–8 h, plus gate reviews and validation approval	Intended use, validation plan and report, role review; no routine bench time
Bench staff	Usability sessions of 1–2 h each for 5–8 people; training of 1–2 h per role	Sessions scheduled outside busy periods [to confirm]
IT	About 40–100 h	Hosting, TLS, identity provider, secrets, backups, monitoring, coordinating the security review; excludes connector development
Compliance/Privacy	About 10–30 h	Data handling review, agreements, minimum-necessary review
Validation	About 60–150 h of testing and documentation, depending on the workflow chosen	One workflow, one bench, narrow intended use
Jorge	Coordination and configuration, with a time agreement [to confirm with his manager]	Never the only person able to support the system (section 13)
Connector development	**Not yet estimated** [to estimate at Gate 1]	Section 4.5; weeks 13–19
Vendor interface fees; external security-test costs	**Unknown until quotes in Phase 2**	No price is assumed
Ongoing support and operations after go-live (updates, backups and restore drills, monitoring, re-validation after changes)	**Not yet estimated** [to estimate at Gate 1]	Depends on the support model chosen at Gate 1; it is a lasting cost, not a one-off

8. IT prerequisites (summary)

The concrete deployment steps for secured mode are in **Appendix A**, each with a reference to the runbook. In short, before Gate 2 IT would provide:

#	Item	Appendix
1	A host (on-premises VM or approved cloud), Node.js 22+, a service account, an encrypted volume	A.1
2	A reviewed build of the application, built with the final public URL	A.2
3	An OpenID Connect app registration (redirect URI `<public URL>/api/auth/callback`) at the organization's identity provider, with MFA by policy	A.3
4	The environment variables, with secrets in a secret store	A.4
5	TLS at a reverse proxy, plain http refused, sign-in rate-limited	A.5
6	Database initialization, once	A.6
7	A service definition that starts secured mode (never `npm start`, which forces demo mode)	A.7
8	Identity links and roles, through `npm run admin`	A.8
9	Encrypted backups and a restore drill (`npm run db:backup` / `db:restore`)	A.9
10	Audit verification and anchors (`npm run audit:verify` / `audit:anchor`)	A.10
11	Health monitoring (`/api/health`) and log handling	A.11–A.12
12	Shared-workstation browser settings	A.13
13	Acceptance checks for the test environment	A.14

9. Validation approach

9.1 Whose responsibility it is

Validation is **the laboratory's responsibility, under its own quality system, with the Medical Director's approval**. This project can supply evidence and help run tests. It cannot validate itself. [to confirm: the lab's accreditation status, its accrediting body, and its quality-system procedures for information systems and document control (*Discovery checklist* 12.6)]

Accreditation requirements to check. The CAP Laboratory General checklist contains information-system requirements, including validation at installation and after changes, and checks of interface result integrity. A 2017 trade-press summary [G6] cites requirement numbers such as GEN.43022 (system testing) and GEN.48500 (interface result integrity). **These numbers must be checked against the current edition.** The same summary notes that validating a new laboratory information system or a major upgrade can involve hundreds of hours of testing. This companion is narrower than a full LIS, but its validation is still substantial: the estimate here is about 60–150 h for one workflow. Whether the current checklist requires approval of the validation by the laboratory director or a designee, and in what form, is for the Medical Director to confirm against the current edition [to confirm]. This guide assumes that approval in any case.

9.2 Start from a written intended use (Phase 1)

The intended use states:

- the one workflow and bench;
- the decisions the tool supports (for example "shows which expected containers have not arrived") and the roles that use it;
- what it never does (it never merges orders, changes identity, issues accessions, or serves as the record of a clinical fact);
- what stays authoritative (EMA, paper procedures);
- the data it receives, and from where.

A narrow intended use keeps validation affordable.

9.3 What the protocol covers (Phase 3)

Area	Examples of what is tested
Requirements from the intended use	Each requirement has a test case, an expected result, the actual result, pass/fail, the tester and the date
Data mapping	Every field from EMA or the LIS appears correctly; identifiers stay in their source namespace
Interface checks	Messages in match records shown; duplicates, amendments, cancellations, out-of-order messages and outages behave as specified; nothing is applied silently
Identity safety	An identity mismatch always goes to a person; nothing is merged; an issued accession never changes
Labels and scanners	The lab's scanners decode the labels after processing [to confirm: solvents and stainers used]; a wrong scan is rejected
Access	Each role can do exactly what it should; leavers lose access; shared-workstation hand-over works
Audit trail	Actions are recorded with who, what, when and why; the chain verifies

Area	Examples of what is tested
Downtime and recovery	The paper fallback works; a restore from backup passes its checks; reconciliation after an outage
Printing	The worklist snapshot prints correctly on the lab's printer

9.4 Using the repository's test suites as supporting evidence

The automated suites (about 800 tests as of 2026-10-24: 643 unit, integration and contract tests; 139 demo browser tests; 26 secured browser tests) should be **re-run on the exact build being validated**, with the results attached to the validation record. They show that the code behaves as designed on synthetic data. **They are not a substitute for the lab's protocol.** They do not test the lab's data, hardware, people or procedures.

9.5 Change control after go-live

Every change goes through the lab's change control: code, configuration, environment variables, interface mapping, identity-provider settings, label formats.

1. Request, with the reason.
2. Impact assessment: does it touch the intended use?
3. Test: the automated suites plus the affected protocol steps.
4. Approval by the Medical Director or designee, as the quality system requires.
5. Deployment at a recorded version. The backup manifest records the application version and git commit.
6. Record kept.

Periodic interface checks follow the current checklist edition [to confirm: frequency]. An emergency-change path is written before go-live.

10. Training and adoption plan

10.1 Principles

- Training happens **before** any patient data, on the synthetic sandbox.
- It is short, role-based and hands-on, built around the guided demo steps.
- It always covers **what the tool does not do**, and the paper fallback.

10.2 Per role (estimates: 1–2 h per role)

Role	What to learn	Format
Accessioners and accessioning lead	Signing in, locking, hand-over; the pilot workflow's screens; what "verified against physical container" means; that identity mismatches always go to the lead; clarifications and holds, if in scope	Hands-on session in the sandbox; quick reference
Grosser and histology assistant	If in scope: the per-part handoff; "entered in EMA (staff attested)" versus "acknowledged by the system"; that EMA remains the record	Hands-on; quick reference
Histotechnologists	If in scope: tray scanning one slide at a time; unknown print outcomes; wrong-block rejection	Hands-on at the bench with the real scanner
Supervisor	Operations view; retrying a failed message; stopping the pilot; the downtime procedure	Hands-on plus a downtime drill
Medical Director and Director of Operations	Operations and measurement views; gate criteria; stop authority	30–60 min walkthrough
Laboratory administrator (IT)	`npm run admin`, backups, restores, audit verification, health, logs	Runbook walk-through, then a supervised drill

10.3 Quick references

One page per role, with:

- how to sign in and lock;
- the three things that matter most for that role;
- what to do when something looks wrong;
- the fallback;
- who to call.

10.4 Superusers

Name superusers for the pilot bench, ideally Phase 1 participants who already know the screens [to confirm: how many, and for which shifts]. They:

- answer first-line questions;
- collect feedback for the weekly review;
- help train new staff.

10.5 Adoption

- Involve bench staff from Phase 0. Their corrections shape the design.

- Report results by team or station, **never as individual rankings**.
- Say clearly what changes and what does not.
- Ask short, structured feedback questions every pilot week (*Pilot proposal* section 6.3).
- Keep training records as the quality system requires [to confirm]. Refresh training after changes, and train new staff before they use it.

11. Downtime, rollback and paper fallback

11.1 Principles (from *Pilot proposal* section 12)

1. EMA and the lab's established procedures stay authoritative in every mode. The companion is never the only place a required fact is kept.
2. The current paper fallback, including any printed worklist, is kept until the lab decides otherwise.
3. Before any shadow or live use: a written fallback, a named person who can stop the pilot, and a rehearsal.

11.2 The paper fallback the software already provides

- **Worklist "Print snapshot."**
  - Each page carries a version number, a snapshot id (`SNAP-…`), the generation time and "Not updated after printing".
  - The paper shows doctor groupings by name and color word, PAS as text, and holds with their scope.
  - A stale source prints **STALE** in the header and on every page.
  - The paper copy shows no patient name, birth date or MRN. It still carries case numbers, so it is a controlled document.
  - Each snapshot is recorded in the audit trail.
  - Evidence: *Print verification*. Paper printing on the lab's printer is checked in Phase 1.
- **CSV export** (`POST /api/worklist/export`).
  - It is a controlled document and says so in its header.
  - It can include hold reasons that quote label details.
  - The application cannot control the file after download. Its storage and deletion follow lab policy [to confirm].
- **Stale marking.** When a source stops responding, screens show the last successful sync and the age of the data, and the worklist is marked stale. It never looks "live" when it is not.

11.3 Scenarios

Scenario	What staff do	What IT does	After recovery
Companion unavailable	Continue in EMA and on paper (last printed snapshot)	Check `/api/health`; follow the runbook (Appendix A.11)	Re-sync; review open items
EMA/LIS feed unavailable	Screens show stale data; use the printed snapshot and established procedures	Check the interface engine and source; the failure queue holds rejected messages	Queued messages are imported once; changes during the outage are reviewed
Identity provider unavailable	People already signed in keep working until their session ends; nobody new can sign in; use paper	Follow the runbook's sign-in section (operations-runbook section 6); **never** switch to demo mode	Normal sign-in resumes
Scanner or printer failure	Established manual procedure [to confirm]	Replace or reconfigure	Reconcile unknown print outcomes before any reprint

Scenario	What staff do	What IT does	After recovery
Database damaged	Paper	Restore the newest verified backup to a new path, review it, repoint, revoke sessions (Appendix A.9)	Work done after the backup is re-entered from paper or EMA and reconciled
Planned maintenance	Print a snapshot first; use paper	Back up before and verify after; anchor the audit chain before and after	Verify health and audit chain

11.4 Stop triggers and rollback (agreed before Phase 4)

Stop triggers

- data mismatch with EMA above an agreed level;
- source data stale beyond an agreed time;
- a safety concern or near miss linked to the pilot;
- staff burden above an agreed limit;
- loss of support;
- any owner withdrawing approval.

Rollback steps

1. The named owner announces the stop.
2. Staff return to the established process.
3. An open-items list is exported, showing its generation time and version.
4. Each open item is confirmed in EMA or existing logs. Nothing is assumed complete.
5. What happened is recorded, and the owners decide whether to resume.

The rollback is **rehearsed in Phase 3** (week 27).

12. Data protection and privacy

Nothing here is a compliance claim. The Compliance/Privacy officer decides what applies.

12.1 Hosting and agreements

- **Where it runs:** an on-premises virtual machine, or a cloud service the provider designates as HIPAA-eligible, under a business associate agreement (BAA) [to confirm with Compliance]. One deployment serves one laboratory.
- **Who may need an agreement before seeing any data** [to confirm with Compliance]:
  - the hosting provider;
  - any contracted developer or support firm;
  - the security tester, if real data is in scope (it should not be);
  - the interface vendor(s).
- **Where data lives:**
  - one SQLite database file and its companion files;
  - backups;
  - an audit anchor file;
  - logs;
  - any downloaded export. All need encrypted storage. **The application does not encrypt its own database file.** Disk or volume encryption is the deployment's job (*Data protection* section 3).

12.2 Minimum necessary

- The application holds three patient identifiers: **name, date of birth and MRN**. It also holds case, order and intake references.
- **Where identification is the task** (intake, identity clarifications, grossing), the identifiers stay on screen, because masking them without a validated workflow could cause a misidentification.
- **Where identification is not the task** (Operations, Insights, the audit report, administrator views, the printed snapshot), the screens use references instead (*Privacy review*).
- The audit trail records **which field changed**, using fingerprints, not the values themselves.
- Notifications to offices carry no patient details.
- **Before Phase 4,** Compliance reviews which fields the chosen workflow actually needs, and whether any screen should show less [to confirm].

12.3 Access

- Sign-in goes through the organization's identity provider. MFA is applied by the provider's policy [to confirm].
- Roles are assigned in the application by a laboratory administrator and reviewed by the Medical Director.
- A job title in the provider's directory never grants a permission.
- Administrators and auditors have **no** clinical access.
- Shared workstations need a managed browser profile that clears data at sign-out (Appendix A.13).

12.4 Tamper-evident, not tamper-proof

- The audit chain detects edits made **without** the audit key.
- Someone who holds the database, the key and the anchor storage together could rewrite history.
- So the key, the backups and the anchor file are kept apart, under different custody [to confirm: who holds each] (*Audit integrity* section 1).

12.5 Retention decisions the lab owes

Data	What the application does today	Decision needed
Clinical and operational records	Kept indefinitely; no deletion path	Apply the lab's record-retention schedule [to confirm]
Audit trail	Kept indefinitely; no deletion path	Retention and any archive that keeps the chain verifiable [to confirm]
Sign-in sessions	Kept indefinitely after expiry (a known gap)	A retention period, and a purge to build [to confirm]
Raw interface messages	Kept indefinitely; they contain patient identifiers (a known gap)	A retention period for raw payloads [to confirm]
Idempotency receipt tombstones	Purged after `HLOS_RECEIPT_TOMBSTONE_DAYS` (default 30)	Accept or change the default
Backups	Nothing deleted by the application	Number, period, off-host copies; a backup kept longer than a record's retention keeps that record [to confirm]
Logs and the anchor file	Not stored or managed by the application	Retention and encrypted storage [to confirm]
CSV exports and printed snapshots	Controlled documents, once outside the application	Storage and destruction rules [to confirm]
Recovery targets (RPO, RTO)	Unknown; must be measured in a drill	How much work may be lost, and how fast service must return [to confirm]

Secure deletion. Deleting rows does not erase them from disk, from snapshots or from backups. When data must be unrecoverable, the deployment destroys the encryption key of the volume and of every backup made with it (crypto-erase), after accounting for each copy (*Data protection* section 7).

12.6 Before any real data

A privacy review by the Compliance/Privacy officer is required (*Privacy review*). Discovery and Phases 0–1 never touch patient data. Observation notes contain no patient identifiers.

13. Support and maintenance model

13.1 The single-developer risk

Today one person (Jorge) built the software, outside any IT team. That is fine for a demonstration and **not acceptable for patient-data use**. If he is unavailable, nobody can fix, update or safely restore it.

- **At Gate 1 (week 10):** the sponsor chooses the support model and names the developer who will build the connector (internal IT or contracted). Jorge is never the only developer of code that receives test or real patient messages.
- **By Gate 3 (week 28):** the support owner and a second maintainer are in place.

13.2 Options

Option	What it means	Needs	Advantages	Drawbacks	Unknowns
1. Internal IT ownership	The organization's IT team owns the code, hosting, updates and on-call	Staff comfortable with Node.js, TypeScript and SQLite; time	Under the organization's control; aligned with IT policy	Competes with other IT work	[to confirm: IT capacity and skills]
2. Contracted developer or firm	A support agreement with a developer or firm, under IT's oversight	A contract, agreements for data access if any, a defined response time	Dedicated skills	Recurring cost (unknown until quoted); vendor management	Cost, availability, agreement terms
3. A vendor product instead	Gate 0 or Gate 5 chooses an existing product; the companion is retired	Procurement	Vendor support and roadmap	Purchase and interface cost; may not fit every gap	Quotes
Jorge's role (with 1 or 2)	Product owner and superuser: requirements, training, testing, feedback	A time agreement [to confirm with his manager]	Knows the workflow and the code	**Never the sole maintainer**	His time and role

13.3 Minimum conditions before patient data (checked at Gate 3)

- A named support owner, and at least one second person who can build, deploy, back up and restore the system from the runbook.
- Support hours that cover the pilot hours [to confirm], and an escalation path.
- The source code repository under the **organization's control**, not a personal account [to confirm: where]. This is already an entry criterion of Phase 1 (section 5.2).
- **The early prompt file.** One early prompt file that Jorge wrote for the AI coding assistant names the employer and one real role-holder. It holds no patient data and no employer documents. It is still in the project folder and in a private copy on Jorge's personal GitHub account [to confirm: that the repository is private]. Jorge deletes it and purges it from the history and the GitHub copy before [to confirm: date], and in any case before the code is shared (*Security and privacy notes*, privacy notes). Its contents are not quoted anywhere.
- A dependency-update routine. Versions are pinned exactly today, so updates are deliberate, tested and recorded.
- The change control described in section 9.5.
- An exit plan: export open items, return to paper and EMA, and retire the system, with data handled under the retention decisions.

- Ownership and intellectual-property questions for an employee-built tool settled in writing with HR, in Phase 0 [to confirm with HR and, if needed, legal]. That includes where the code was kept (a personal GitHub account) and the identity on its commits (*Director FAQ*, question 13).

13.4 Where the software and data live, and who may change them

Item	Where	Who may change it
Source code	The organization's repository [to confirm]	The support owner, through change control; reviewed by a second person
Running application	The test or pilot host (section 12.1)	IT, through change control
Configuration and secrets	The service definition and the secret store	IT; secrets readable only by the service account and named administrators
Database	Encrypted volume on the host	The application only; no manual edits. Repairs go through restore (Appendix A.9)
Backups	Encrypted, with off-host copies [to confirm]	IT; reads and restores recorded
Audit anchor file	Storage that the database administrators cannot change [to confirm]	A different custodian [to confirm]
Staff identity links and roles	In the application, through `npm run admin` (audited)	The laboratory administrator; reviewed by the Medical Director
Routing rules and office contacts	In the application, through its Settings screens (versioned, audited)	Roles the application allows; approved as the lab decides [to confirm]
Intended use, validation records, SOPs	The lab's document control	The Medical Director and quality system

14. Risk register

Likelihood (L) and impact (I) are **initial judgements** (Low, Medium, High), to revisit at Gate 0 and at each gate.

#	Risk	L	I	Mitigation	Owner
1	**Vendor delay.** The interface specification, test environment or contract takes longer than planned.	High	High	Start vendor scoping in week 1 of Phase 0, with no contract. Phase 1 needs no vendor. Gate 1 allows a pause. If the test environment is not ready by about week 15, switch to the 12-month plan. Stopping after Phases 0–1 is an acceptable outcome.	Sponsor
2	**Cost of the interface.** Fees, interface-engine work, connector development or ongoing support cost more than the benefit justifies.	Medium	High	No commitment before quotes in Phase 2. Compare with *configure* and *buy* at Gates 0 and 2. Estimate connector effort and ongoing support at Gate 1.	Sponsor, IT lead
3	**Staff time.** Sessions, training and the pilot take time from bench work.	Medium	Medium	Short sessions (1–2 h), scheduled outside busy periods [to confirm]. The sponsor protects the time. Effort is tracked against the estimates.	Sponsor, supervisor
4	**Double entry.** Shadow or live use requires typing data into two systems.	High (without a feed)	High	Choose a pilot workflow fed by the interface. Time-limit shadow mode to about 2 weeks. Measure double entry as a balancing measure. A stop trigger applies if it exceeds the agreed limit.	Sponsor
5	**Scope creep.** New ideas (instruments, analytics, AI) are added before the first workflow is proven.	Medium	Medium	One workflow, one bench. The roadmap's rule for moving an idea into a build (*Roadmap* section 1). Changes go through the sponsor at a gate.	Sponsor
6	**Prompt and reminder fatigue** (the alarm-fatigue analogue). Too many confirmations or reminders lead people to click through without reading, which removes the safety value of the checks.	Medium	High	Interrupt only when it changes the next action. Duplicate reminders are already suppressed. Measure verification burden and notification volume weekly (*Pilot proposal* section 6.3). Remove prompts that do not earn their place.	Medical Director, supervisor
7	**Identity errors.** A patient or specimen identity is linked wrongly through the tool, or a sign-in identity is linked to the wrong staff member.	Low	High	The tool never merges, never relinks an accessioned case, and sends every identity mismatch to a lead. A scan never marks a container as verified. EMA remains authoritative. Validation tests identity paths. Identity links are reviewed by the Medical Director, and leavers are deactivated.	Medical Director, lab administrator
8	**Downtime.** The companion, the feed or the identity provider is unavailable during work.	Medium	Medium	Paper fallback and stale marking. EMA stays authoritative. Restore drills. A rehearsed downtime procedure. Health monitoring.	IT lead, supervisor
9	**Security.** A vulnerability exposes patient data.	Low–Medium	High	Independent security review before Gate 2. TLS, provider sign-in with MFA by policy, encrypted storage, secrets in a secret store, least privilege, no patient fields in logs. Known open items are fixed or formally accepted.	IT lead, Compliance/Privacy officer
10	**Support continuity.** The single-developer risk: no one can fix or update the system.	High (today)	High	A named connector developer other than Jorge at Gate 1, before any interface work. A support owner and a second maintainer before Gate 3. Repository under organization control from Phase 1. Runbooks and tests exist. Exit plan.	Sponsor

#	Risk	L	I	Mitigation	Owner
11	**Change resistance.** Staff see the tool as extra work or as surveillance.	Medium	Medium	Involve staff from Phase 0. No individual rankings. Act on usability findings. Weekly feedback. Be honest that *configure* or *stop* are good outcomes.	Sponsor, supervisor
12	**Validation effort underestimated.** Validation takes longer than 60–150 h.	Medium	Medium	A narrow intended use. Plan validation from week 20. Re-use the automated suites as supporting evidence. The Medical Director scopes the work early.	Medical Director
13	**The companion becomes a second record.** People treat it as authoritative and stop checking EMA.	Medium	High	Intended use and training say EMA is the record. Labels distinguish "staff attested" from "system acknowledged". Data agreement checks during the pilot.	Medical Director
14	**Observer effect and an unrepresentative baseline.** People work differently while observed; a few weeks miss seasonal patterns.	Medium	Medium	Same observers and definitions before and after. Report counts and ranges. Note unusual days.	Jorge, sponsor
15	**Hardware fit.** The lab's scanners, label stock or printers do not work with the formats, or labels do not survive processing.	Medium	Medium	Bench checks in Phase 1. Validation in Phase 3. Vendor support for printer drivers if needed.	Supervisor, IT lead
16	**Data exposure on shared workstations and exports.** Downloaded CSV files or browser history keep identifiers.	Medium	Medium	A managed kiosk browser profile. Exports treated as controlled documents. Training. Autofill settings reviewed.	IT lead, Compliance/Privacy officer
17	**Employer policy and time.** Policies on employee-built tools or on AI coding assistants, or Jorge's availability, slow or stop the work.	Medium	Medium	Check policies in Phase 0 (*Discovery checklist* 12.5), including the use of an AI coding assistant. Settle ownership in writing. A time agreement. A support owner who is not Jorge.	Sponsor, HR
18	**Accessibility not proven.** A staff member who relies on assistive technology cannot use the tool.	Low–Medium	Medium	Run the screen-reader checklist in Phase 1. Keep the established process available.	Jorge, supervisor
19	**No order interface at all.** The lab works inside EMA's Pathology module, so orders never travel over HL7 to a separate system (section 4.1).	Unknown [to confirm]	High	The first question in Phase 0. If so, ask ModMed whether its API gives access to that data; if it does not, choose configure, buy or stop at Gate 0.	Sponsor, IT lead

15. Decision checklist for the Director (one page)

Approve now: Phase 0 only (4 weeks; no patient data, no software installed on lab systems, no purchase)

- ☐ **Sponsor:** the Director of Operations, about 1 h per week, plus the Gate 0 decision.
- ☐ **Phase 0 group:** the Medical Director, the IT lead, the Compliance/Privacy officer and Jorge [to confirm: who fills each role].
- ☐ **Observation:** Jorge may observe and time a few representative workflow cycles, **with the staff's agreement**, recording **no patient identifiers**.
- ☐ **Demo review:** a 30-minute small-group review (accessioner, grosser, histotechnologist, supervisor) of the synthetic demo, to say what is wrong.
- ☐ **Questions to vendors:** questions to ModMed, and to any LIS vendor, about what is licensed, configurable and interfaced, sent through [to confirm: the EMA administrator or the IT lead]. **Questions only: no contract, no data shared.**
- ☐ **Time:** Jorge's time for Phase 0 is agreed [to confirm with his manager].
- ☐ **Policies:** employer policies on employee-built tools, on this work and on AI coding assistants are checked, and ownership is settled in writing [to confirm with HR].
- ☐ **Gate 0 date:** a 30-minute review in week 4 [to confirm: date].

Phase 0 only: rough effort (estimates to refine at the kickoff)

Who	Phase 0 effort
Sponsor (Director of Operations)	About 4 h over the 4 weeks, plus the Gate 0 decision
Medical Director, IT lead, Compliance/Privacy officer	[to estimate at kickoff: a 30-minute kickoff, a 30-minute Gate 0 review, plus answers to their discovery items]
Jorge	[to confirm: hours per week for 4 weeks, agreed with my manager, and who covers my bench while I observe]

Not being approved now

- Any purchase, budget or contract.
- Access to EMA, the lab network, patient data or payroll data.
- Installing anything on a lab system, including the sandbox.
- Contact with any submitting office.
- Any endorsement or partnership.

Decided later, at the gates

Decision	When (weeks from approval)	Who decides
Configure, buy, build or stop, gap by gap	Gate 0 (week 4)	Sponsor, with the Medical Director
Install the sandbox on a lab-controlled computer	Gate 0 (week 4)	IT lead
Intended use; go or no-go for Phase 2	Gate 1 (week 10)	Medical Director; sponsor
Support model chosen; connector developer named (never Jorge alone)	Gate 1 (week 10)	Sponsor
Hosting, identity-provider registration, security review, vendor contract and fees; BAA and data agreements	Phase 2 (after Gate 1)	Sponsor, IT lead; Compliance/Privacy officer for agreements
Test environment and interface feasible	Gate 2 (week 22 in the best case)	Sponsor, IT lead
Validation plan and report	Phase 3	Medical Director
Support owner and second maintainer in place	Gate 3 (week 28)	Sponsor
Pilot with patient data, one workflow, one bench	Gate 3 (week 28)	Sponsor and Medical Director
Continue, expand, change or stop	Gate 5 (week 38)	Sponsor and Medical Director

What success looks like: the problem gets solved, even if this software is not what solves it.

16. Glossary

Term	Meaning
Accession	The lab's official case record and number for a specimen (issued by EMA or the LIS)
Anchor (audit)	A copy of the audit chain's latest seal, kept outside the database, so later rewriting can be detected
Audit trail	The record of who did what, when and why
BAA (business associate agreement)	A contract that covers how an outside party handles protected health information; whether one is needed is decided by Compliance
Balancing measure	A measure that catches harm or extra work caused by a change (for example, added checking time)
Block / cassette	The tissue embedded in paraffin, in a labeled cassette, from which slides are cut
Companion	Software that works next to EMA and coordinates handoffs, without replacing EMA
Demo mode / secured mode / locked mode	The three ways the software can run: synthetic demo with a role switch; real sign-in required; or shows nothing because it is not configured
Double entry	Typing the same information into two systems
EMA	ModMed's electronic medical record system, used by the practice
FHIR	A modern standard for exchanging health data over the web (version R4 is common)
Gate	A decision point at the end of a phase where the plan can continue, change or stop
Gross description	The written description of a specimen as received and cut
HL7 v2	An older, widely used standard for health messages; ORM messages carry orders and ORU messages carry results
HSTS	A web setting that tells browsers to use only encrypted (https) connections to the site
Identity provider (IdP)	The organization's sign-in service, for example Entra ID or Okta
Idempotency	A safeguard so that repeating the same request (a double click, a retry) does not record the action twice
Intended use	A written statement of what the software is for, who uses it, and what it never does
Interface engine	Software that translates and routes messages between systems
LIS	Laboratory information system
MFA	Multi-factor authentication: signing in with something more than a password
MLLP	The usual network transport for HL7 v2 messages
OIDC (OpenID Connect)	A standard way for an application to let the organization's identity provider sign people in
OAuth 2.0 / SMART on FHIR	Standards for authorizing an application to read health data through a FHIR API
PAS	Periodic acid–Schiff, a special stain
Penetration test	An independent attempt to break into the system to find weaknesses
PHI	Protected health information
RACI	Responsible, Accountable, Consulted, Informed
Reconciliation	Comparing what the source system says with what the lab recorded, and showing differences to a person

Term	Meaning
Reverse proxy	A server in front of the application that handles encryption (TLS) and limits traffic
Rollback	Returning to the established process when a pilot is stopped
RPO / RTO	Recovery point objective (how much recent work may be lost) / recovery time objective (how quickly service must return)
Shadow (parallel) mode	Running the new tool alongside the usual process without relying on it, to compare
Staff attestation	A named person confirming in the companion that something was done in EMA; never shown as a system acknowledgement
Superuser	A trained staff member who helps colleagues and collects feedback
Synthetic data	Made-up data with fictional people and organizations
Tamper-evident	Changes can be detected afterwards; not the same as tamper-proof
"The bible"	The lab's printed, color-coded daily case list by doctor (as observed by the author)
TLS	The encryption used by https
Validation	Documented evidence, under the lab's quality system, that a system does what its intended use requires
VM	Virtual machine: a server that runs in software on shared hardware

Appendix A. IT prerequisites: secured-mode deployment steps

*For the IT lead. These steps set up a **secured test environment** (Phase 2) with **synthetic data**. Nothing here authorizes real patient data; that needs Gates 2 and 3. Every variable, script and route below was checked against the code (`src/server/auth/config.ts`, `src/server/runtime-mode.ts`, `src/server/db/db.ts`, `package.json`, `src/app/api/**`). Runbook references are to the release documents in the repository's `docs/release/` folder.*

A.1 Host

- One host: an on-premises VM or an approved cloud instance [to confirm with Compliance]. One deployment serves **one** laboratory.
- **Node.js 22 or later** (`package.json` engines).
- A dedicated service account. The database directory is readable only by that account.
- An **encrypted volume** for the database (`-wal` and `-shm` files included), the system temporary directory SQLite may use, backups, the anchor file and logs. The application does not encrypt its database file (*Data protection* section 3).
- Disk space for the database plus at least one full extra copy during a backup or restore (*Backup and restore* section 5, item 8).
- **One application process on one host.** Concurrency beyond a single SQLite file on one host is not verified (*Production readiness*).

A.2 Build

```
npm ci                                          # exact versions from package-lock.json
HLOS_PUBLIC_URL=https://<host> npm run build    # the build generates the schema module first
(prebuild)
```

- **Build with the final https `HLOS_PUBLIC_URL`.** HSTS is decided when the build is made (`next.config.ts`). A build made without it sends no HSTS, unless the proxy sets it (*Data protection* section 2.3).
- The build needs no network after the packages are installed.
- Record the git commit deployed. `HLOS_GIT_COMMIT` overrides the commit recorded in backup manifests.

A.3 Identity-provider registration (*Sign-in architecture* sections 2, 3 and 6)

Setting	Value
Protocol	OpenID Connect, authorization code flow with PKCE; issuer discovery
Client type and authentication	Confidential client, `client_secret_basic`
Scope requested	`openid`
Redirect URI	`<HLOS_PUBLIC_URL>/api/auth/callback`, registered exactly as written
Post-logout redirect URI	`<HLOS_PUBLIC_URL>/signed-out`
Claims needed	A stable `sub` (subject); `auth_time` (the app sends `max_age` on every sign-in); optionally a claim naming the lab, set as `HLOS_OIDC_LAB_CLAIM`
Behavior needed	Honor `prompt=login` and `max_age=0`. Every sign-in forces a fresh authentication, so a previous person's single-sign-on session never signs the next person in.

Setting	Value
MFA	Enforced by the provider's policy [to confirm]. **The application does not check `amr`/`acr` yet**; adding that check needs the provider's values.
Provider	The organization's existing one, for example Entra ID or Okta [to confirm]

A.4 Environment variables (*Data protection* section 4; *Audit integrity* section 8; *Operations runbook*)

Generate every secret with `openssl rand -hex 32` and keep it in the secret store. Each secret keys one thing only. The application refuses missing, reused, short or weak secrets by locking the build. The `/locked` page shows no keys. The server log line `runtime.locked_misconfigured` names the failing variables, never their values (a warn line, shown unless `HLOS_LOG_LEVEL=error`).

Required for secured mode (any missing or invalid value means the build is **locked**: every page goes to the "not configured" page `/locked`, which shows no keys)

Variable	Purpose	Rule checked by the application	Keep in
`HLOS_MODE`	`secured`	Any value other than `demo` or `secured` locks the build; so does `secured` with any invalid setting below	Service definition
`HLOS_OIDC_ISSUER`	The provider's issuer URL	https; no user, password, query or fragment	Service definition
`HLOS_OIDC_CLIENT_ID`	Client id from A.3	Visible ASCII, no spaces	Service definition
`HLOS_OIDC_CLIENT_SECRET`	Client secret	At least 16 characters; not weak; not equal to `HLOS_SESSION_SECRET` or `HLOS_AUDIT_KEY`	Secret store
`HLOS_PUBLIC_URL`	Public origin, for example `https://<host>`	https with a real provider; no path, query or fragment	Service definition **and** build environment
`HLOS_LAB_ID`	The one lab this deployment serves (for example `lab:local`)	Letters, digits, `: . _ -`; up to 100 characters	Service definition
`HLOS_SESSION_SECRET`	Binds a sign-in transaction to its browser	At least 32 bytes; not weak	Secret store
`HLOS_AUDIT_KEY`	Seals the audit chain	At least 32 bytes; not weak; not the session secret; not the public demo key	Secret store, **apart from backups**

Optional, with defaults

Variable	Default	Allowed	Purpose
`HLOS_OIDC_LAB_CLAIM`	none	Claim name	The ID token claim that must contain `HLOS_LAB_ID`
`HLOS_SESSION_IDLE_MIN`	15	1–240	Idle lock, in minutes
`HLOS_SESSION_MAX_HOURS`	12	1–24	Absolute session lifetime
`HLOS_REAUTH_MAX_AGE_MIN`	5	1–60	How fresh a sign-in must be for sensitive commands
`HLOS_AUDIT_KEY_ID`	Derived from the key	`A-Z a-z 0-9 . _ : -`, up to 64; not `demo-not-secret`	Name recorded on each seal

Variable	Default	Allowed	Purpose
`HLOS_AUDIT_ANCHOR_PATH`	none (**strongly advised**)	Outside the database's directory	Anchor file, on storage the database administrators cannot change
`HLOS_DB_PATH`	`data/histology-lab-os.db`	Path on the encrypted volume	Database file
`HLOS_BACKUP_KEY`	none (**required for backups outside the demo**)	32 bytes, as 64 hex characters or base64; not equal to any other secret	Backup encryption; keep it apart from the backups
`HLOS_BACKUP_DIR`	`data/backups/`	Directory	Where backups go; the health check watches only this directory
`HLOS_BACKUP_MAX_AGE_HOURS`	26	1–8760	Health warns when the newest backup is older
`HLOS_RECEIPT_TOMBSTONE_DAYS`	30	1–3650	Retention of receipt tombstones
`HLOS_HEALTH_AUDIT_VERIFY_MINUTES`	15	1–1440	Background audit-chain verification interval
`HLOS_LOG_LEVEL`	`info`	`debug`, `info`, `warn`, `error`	Log threshold
`HLOS_GIT_COMMIT`	from git	A git commit hash (7–40 hex characters); anything else is ignored and the commit is read from git	Commit recorded in backup manifests

Initialization only (A.6): `HLOS_DB_ALLOW_CREATE=1` (once) or `HLOS_SEED_SYNTHETIC=1` (test environment only).

Never set in a secured deployment

- `HLOS_OIDC_ALLOW_INSECURE_LOOPBACK`: local tests only.
- `HLOS_INTEGRATION_SIMULATOR` and `HLOS_INTEGRATION_SIM_SECRET`: demo only; the endpoint is a 404 outside demo mode anyway.
- `HLOS_TEST_FIXTURES` and `HLOS_TEST_FIXTURE_TOKEN`: demo test suites only.

A.5 TLS and the reverse proxy (*Data protection* section 2)

- Terminate TLS at a reverse proxy, with the organization's certificate. Forward to the application on **loopback** (for example `127.0.0.1:3100`). Keep the proxy-to-application hop on the same host or an encrypted network.
- Refuse or redirect plain http. The application does not redirect.
- Rate-limit `/api/auth/login` and `/api/auth/callback` per client at the proxy. The application leaves per-client rate limiting to the proxy.
- After deployment, check HSTS on a real response: `curl -sI https://<host>/signin | grep -i strict-transport`.

A.6 Database initialization (once) (*Sign-in architecture* section 1, "Seeding"; *Stage 6 verification record* section 4, Phase E)

Outside demo mode, the application **never creates a missing database silently** (`src/server/db/db.ts`).

Environment	How	Notes
Secured test environment (Phase 2)	First start with `HLOS_SEED_SYNTHETIC=1`	Loads the fictional synthetic lab day, including fictional staff to link test identities to. The screens show a persistent "Synthetic data" label. Never use it with real data.
Empty database	First start with `HLOS_DB_ALLOW_CREATE=1`, then remove it	Creates the schema only: **no staff, offices, doctors or routing rules.** There is no command yet to add real staff or load reference data (section 2.3, development item) [to build before any real use].

Never start demo mode against this database. Demo mode refuses a database that has linked sign-in identities.

A.7 Start in secured mode

```
# under a service manager (for example systemd), with the A.4 environment injected from the secret
store
HLOS_MODE=secured npx next start -p 3100
```

- **Do not use `npm start`.** It sets `HLOS_MODE=demo` (`package.json`).
- `npm run start:locked` is the same `next start -p 3100` without a mode, so it inherits whatever `HLOS_MODE` the environment sets.
- If the page shows "not configured" (`/locked`), the build is locked. `/locked` shows no keys: read the server log line `runtime.locked_misconfigured`, fix the variables it names against the A.4 rules, and restart. **Never switch to demo mode to get it running** (*Operations runbook* section 2).

A.8 Identity links and roles (*Sign-in architecture* section 4; `scripts/admin.ts`)

Sign-in never links anyone automatically. A laboratory administrator links each person, and the Medical Director reviews the role assignments. Every command writes an audit event that names the operating-system account that ran it.

```
npm run admin -- list
npm run admin -- link-identity <staffId> --issuer <issuer URL> --subject <sub> [--lab <labId>]
npm run admin -- set-role <staffId> <role>
npm run admin -- deactivate-staff <staffId>          # leavers; also revokes their sessions
npm run admin -- revoke-sessions <staffId>
npm run admin -- unlink-identity --issuer <issuer URL> --subject <sub> [--lab <labId>]
```

- **Roles:** `accessioner`, `accessioning_lead`, `grosser`, `histology_assistant`, `histotech`, `supervisor`, `pathologist`, `director`, `medical_director`, `lab_admin`, `auditor`.
- `lab_admin` and `auditor` have **no** clinical access. They see only `/audit` and the health details.
- `--subject` is the provider's stable `sub` for that person.
- In a synthetic test environment, link test identities to fictional seeded staff. Use `set-role` if a test administrator or auditor is needed.

- Leaver process: disable the account at the provider **and** run `deactivate-staff` [to confirm: who triggers it].

A.9 Backups and restore drills (*Backup and restore*; *Operations runbook* section 5)

```
export HLOS_BACKUP_KEY=…    # from the secret store; not the audit key
npm run db:backup                                  # → <HLOS_BACKUP_DIR>/<id>.sqlite.enc +
<id>.manifest.json
npm run db:restore -- <manifest> --target /isolated/restore-YYYYMMDD.db --anchors
/elsewhere/anchors.jsonl
```

- **Schedule** backups (suggested: nightly and before every upgrade [to confirm]). They are safe while the application runs.
- Copy backups **off the host** [to confirm: where]. Record who reads, restores or deletes them.
- **Drill** at least monthly and after every upgrade (suggested): restore into an isolated path, read the report, then delete the copy.
- A restore never overwrites anything, and the application never switches to a restored database by itself. After review, repoint `HLOS_DB_PATH`, restart, and run `npm run admin -- revoke-sessions <staffId>` for affected staff, because sessions come back as they were at backup time.
- **Losing `HLOS_BACKUP_KEY` loses every backup made with it.** Decide key custody and escrow [to confirm].
- **RPO and RTO are unknown** and must be measured in a drill on the real host (*Backup and restore* section 3).

A.10 Audit verification and anchors (*Audit integrity*; *Operations runbook* section 3)

```
npm run audit:verify     # exit 0 verified, 1 a problem, 2 configuration error
npm run audit:anchor     # verifies, then appends the chain head to HLOS_AUDIT_ANCHOR_PATH
```

- Run `audit:anchor` at least daily, and before and after maintenance (suggested).
- Keep the anchor file where the database administrators cannot change it [to confirm: custodian].
- The `/audit` page and `POST /api/audit/verify` offer the same check to the `lab_admin` and `auditor` roles, with an evidence download that contains no event content.
- **On a failure:** do not write to or repair the database; copy the files; download the evidence; restore the newest verified backup to a new path and compare; escalate under the incident procedure.
- Also run `npm run maintenance` daily: it compacts expired receipts and purges old tombstones, and prints counts only (*Operations runbook* section 4).

A.11 Health monitoring (*Operations runbook* section 2)

Endpoint	For	Answer
`GET /api/health`	Uptime monitor, load balancer (no sign-in)	`healthy` or `degraded` (HTTP 200), or `unavailable` (HTTP 503); no details
`GET /api/health/details`	A signed-in `lab_admin` or `auditor` in secured mode	Each check: process, database, audit chain, receipt maintenance, integration sources, import failures, backup age

- Alert on `unavailable`. Review `degraded` from the details page.

- **Known limits:** monitoring tools cannot read the details in secured mode (no service-account path); a full disk can still pass the write probe, so monitor disk space separately; the backup check sees only `HLOS_BACKUP_DIR`.

A.12 Log handling (*Operations runbook* section 1)

- One JSON object per line. `info` and `debug` go to stdout; `warn` and `error` go to stderr. Use `HLOS_LOG_LEVEL` to set the threshold.
- The application stores no logs. Collect them, keep them on encrypted storage, and set their retention [to confirm].
- By design, log lines carry no cookies, tokens, secrets, request bodies or patient fields, and long digit runs and date-like values are scrubbed. **Limitation:** a person's name inside free text cannot be recognized by pattern.
- To follow one request into the audit trail, use the correlation id.

A.13 Shared workstations (*Privacy review* section 5)

- Use a managed browser profile that clears data at sign-out (kiosk-style) [to confirm: IT standard].
- Review browser autofill on bench fields. The application does not yet set `autocomplete="off"` on fields that take bottle identifiers.
- Set rules for the Downloads folder (CSV exports) and the print spooler.
- The application already locks after `HLOS_SESSION_IDLE_MIN`, removes page content on lock, and refuses actions from a different person (`ACTOR_MISMATCH`).

A.14 Acceptance checks for the test environment (before Gate 2) (*Sign-in architecture* section 6; *Operations runbook*; *Stage 6 verification record* section 1)

#	Check	Expected
1	Open the site over https	Sign-in page; HSTS header present
2	Remove one required variable and restart (negative test)	Locked: no data; every page goes to `/locked`; `/api/health` answers 503; the server log shows `runtime.locked_misconfigured` naming the removed variable
3	Sign in as a linked test user	The user's role screens only
4	Sign in as an unlinked user	Denied; no session
5	Lock, then unlock as a different user	Hand-over: the old session is revoked; nothing is attributed to the wrong person
6	Sign in as `lab_admin`	`/audit` only; bench screens forbidden
7	`npm run db:backup`, then `npm run db:restore` to a new path	Every check passes
8	`npm run audit:anchor`, then `npm run audit:verify`	Verified, with anchors
9	`GET /api/health`	`healthy` (or `degraded` with an understood reason)
10	Re-run the automated suites on the deployed commit (`npm run check`, `npm run test:e2e`, `npm run test:e2e:secured`) on a build machine	All pass; results kept as supporting evidence

#	Check	Expected
11	Test interface messages through the interface engine (once the connector exists)	Accepted, duplicate, stale and rejected cases behave as in *Integration contract*

A.15 Integration work (development, not configuration) (*Integration contract*; *Integration readiness*)

See section 4.5. Today `POST /api/integration/inbound` exists only in demo mode, with simulated sources, and returns 404 in secured mode. A real connector needs:

- an independent secret or certificate per source;
- the transport IT chooses (VPN or mutual TLS; HL7 v2 over MLLP, or FHIR over https, through the interface engine);
- an interface agreement covering identifiers and namespaces, message ids that are never reused, ordering, retries, error replies, and backlog replay after downtime (*Integration readiness*).

The read-only reconciliation view (`GET /api/integration/reconciliation`, screen `/integration`) is already built for operators to check the result.

Appendix B. Evidence index

Document	What it shows
Stage 6 verification record	Test counts, how each gate was run, defects found and fixed, open items
Production readiness	Verified, implemented-not-verified, simulated, planned, blocked, requires human validation
Security and privacy notes	Security controls and production blockers
Sign-in architecture	Modes, sign-in, sessions, roles, activation checklist
Data protection	Transport, storage, secrets, retention, secure deletion
Privacy review	Patient identifiers on each screen, in exports, logs and the audit trail
Audit integrity	The audit chain, anchors and their limits
Integration contract	The `hlos.source-message` 1.0 contract, the 12 simulated scenarios, HL7/FHIR comparison
Integration readiness	Each adapter boundary and what a real one must provide
Backup and restore	Backup and restore design, a synthetic drill, limitations, RPO/RTO
Operations runbook	Logs, health, audit verification, maintenance, backup drill, sign-in failures
Screen-reader checklist	The screen-reader test plan (not yet run)
Print verification	Print-to-PDF checks and the human checklist for paper
Touch targets	Pointer target measurements; touchscreen unknowns
Stage 7 proposal	A future architecture, not built, including how any AI would be constrained
Demo runbook	How to run the eight-step demo
Pilot proposal	Options, metrics (section 6), value counting, rollout modes, rollback
Discovery checklist	The questions for Phase 0
Research notes	What each earlier source does and does not establish

Appendix C. Sources

Public pages, used as context only. **Each vendor statement must be confirmed with the vendor, and each checklist item against the current edition.** The ModMed pages are protected against automated readers. On 2026-10-24 their titles resolved, but their content could not be read automatically, so a person should re-read them in a normal browser before the meeting (the same caution as *Research notes*, item 2).

- **[G1]** ModMed, HL7 Connectivity. https://www.modmed.com/synapsys/hl7/ (previously read and summarized as R3 at https://www.modmed.com/what-we-do/integrations/synapsys/hl7/ in *Research notes*).
- **[G2]** ModMed, "Connect Your Lab with EMA EHR, Orders & Results Interface". https://www.modmed.com/?p=31624
- **[G3]** ModMed, lab connection page. https://www.modmed.com/lab-connect/ (its title matched [G2] on 2026-10-24; it may be the same page).
- **[G4]** ModMed API portal. https://portal.api.modmed.com (see also R2 and R4 in *Pilot proposal*, and section 4 of *Research notes*).
- **[G5]** LigoLab, "Seamless diagnosis mapping: why LigoLab's ModMed integration matters for dermatopathology" (vendor blog). https://www.ligolab.com/post/seamless-diagnosis-mapping-why-ligolabs-modmed-integration-matters-for-dermatopathology
- **[G6]** Medical Laboratory Observer, "The inspection-ready lab includes IT" (2017). https://www.mlo-online.com/information-technology/lis/article/13009283/the-inspectionready-lab-includes-it
- **[R1]–[R12]** as listed in *Pilot proposal*.

None of these sources describes this laboratory's configuration, contracts or permissions.